

Clase 192 — Detección de movimiento lateral

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Blue Team Handbook* — Don Murdoch · MITRE ATT&CK (Lateral Movement) 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Detectar cómo un atacante se desplaza de un host comprometido a otros dentro de la red: PsExec/servicios remotos, WMI, WinRM, RDP, Pass-the-Hash y abuso de credenciales. Aprenderás qué huellas dejan estas técnicas en Event Logs, Sysmon y telemetría de red, y cómo distinguirlas de la administración legítima.

⚠️ **Ética:** las técnicas ofensivas descritas se ejecutan únicamente para generar telemetría de detección en tu laboratorio propio y aislado, o con autorización explícita. El objetivo de la clase es defensivo.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Enumerar** las técnicas de movimiento lateral más comunes y sus artefactos.
- 2. **Detectar** ejecución remota (PsExec, WMI, WinRM) en logs de Windows.
- 3. **Identificar** Pass-the-Hash y uso anómalo de credenciales.
- 4. **Distinguir** administración legítima de movimiento lateral malicioso.
- 5. **Escribir** detecciones y mapearlas a la táctica Lateral Movement de ATT&CK.

📖 Temas

#	Tema	Por qué importa
1	Táctica Lateral Movement (ATT&CK)	Marco de referencia
2	PsExec y servicios remotos	Técnica clásica y muy usada
3	WMI y WinRM	Ejecución remota "living off the land"
4	RDP y logon type 10	Movimiento interactivo
5	Pass-the-Hash / Overpass-the-Hash	Reutilización de credenciales
6	SMB, shares admin y admin\$	Vías de propagación
7	Logon patterns y grafos de acceso	Detectar rutas anómalas
8	Baseline de administración legítima	Reducir falsos positivos

Definiciones y características

- **Movimiento lateral:** conjunto de técnicas para moverse por la red tras el compromiso inicial. Característica: usa credenciales y protocolos legítimos, difícil de separar del uso normal.
- **Psexec:** herramienta que ejecuta comandos remotos creando un servicio. Característica: deja Event 7045 (servicio instalado) y accesos SMB al admin\$.
- **WMI lateral:** ejecución remota vía `wmic / Win32_Process`. Característica: proceso hijo de `WmiPrvSE.exe`, poco ruido de servicio.
- **WinRM:** gestión remota vía PowerShell Remoting. Característica: procesos hijos de `wsmpovhost.exe`.
- **Pass-the-Hash (PtH):** autenticación con el hash NTLM sin conocer la contraseña. Característica: logon NTLM (4624 tipo 3) sin el correspondiente Kerberos esperado.
- **Logon Type 3/10:** red (SMB/WMI) e interactivo remoto (RDP). Característica: pistas para clasificar el tipo de acceso.
- **Event 4648:** logon con credenciales explícitas. Característica: frecuente en overpass-the-hash y uso de credenciales robadas.

Herramientas y preparación

En laboratorio aislado con un dominio de pruebas:

- **Sysmon** y auditoría avanzada en varios Windows unidos a un AD de laboratorio.
- Herramientas para **generar** la telemetría: PsExec (Sysinternals), `wmic`, PowerShell Remoting; y, con fines de laboratorio, utilidades como Mimikatz/CrackMapExec para simular PtH.
- Tu SIEM recibiendo los eventos de todos los hosts.
- Opcional: **BloodHound** para razonar sobre rutas de ataque de identidad.

Ejecuta las técnicas ofensivas solo contra tus propias máquinas y con conocimiento pleno.

Laboratorio guiado — Sigue el rastro lateral

1. **Prepara el dominio.** 1 DC + 2 workstations de laboratorio con Sysmon y auditoría de logon habilitada.
2. **Genera PsExec.** Ejecuta un comando remoto benigno con PsExec desde host A a host B y observa: Event 7045 (servicio), 4624 tipo 3, accesos a `\\B\ADMIN$`.
3. **Genera WMI.** Lanza `wmic /node:B process call create "cmd /c whoami"` y localiza el proceso hijo de `WmiPrvSE.exe` en Sysmon Event 1.
4. **Genera WinRM.** Con `Invoke-Command -ComputerName B` observa procesos bajo `wsmpovhost.exe`.
5. **Simula PtH.** En laboratorio, autentícate con hash a host B y detecta el 4624 NTLM tipo 3 sin actividad Kerberos previa coherente y con 4648.
6. **Detecta RDP.** Inicia una sesión RDP y localiza 4624 tipo 10 más los eventos TerminalServices.
7. **Construye detecciones.** Escribe reglas para: instalación de servicio remoto inusual, proceso hijo de `WmiPrvSE` lanzando shells, y logon NTLM tipo 3 desde workstation a workstation (patrón raro).
8. **Baseline.** Excluye las cuentas y hosts de administración legítima para bajar falsos positivos.

Ejercicios

1. Mapea 5 técnicas de movimiento lateral a sus Event IDs/artefactos.

2. Escribe una detección de "workstation-a-workstation SMB admin\$" (patrón inusual).
3. Diferencia el rastro de PsExec, WMI y WinRM en una tabla.
4. Explica cómo detectarías Pass-the-Hash con eventos de logon.
5. Diseña una baseline de administración legítima para tu entorno.
6. Usa un grafo de logons para detectar un pivote anómalo.

Reto verificable

Genera y detecta al menos tres técnicas de movimiento lateral distintas en tu dominio de laboratorio, entregando por cada una la telemetría, la detección y la técnica ATT&CK. **Criterio de aceptación:** cada detección dispara con la técnica correspondiente y no con la administración legítima de tu baseline; distingues correctamente PsExec de WMI de WinRM por sus artefactos característicos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Falsos positivos con admins de TI	Sin baseline de administración; excluye cuentas/hosts legítimos
No detectas WMI/WinRM	Faltan Sysmon y auditoría de proceso; habilítalos en todos los hosts
PtH invisible	No correlacionas NTLM vs Kerberos; añade lógica de logon anómalo
Solo miras un host	El movimiento lateral es multi-host; correlaciona en el SIEM
Ruido de escáneres internos	Herramientas de inventario parecen laterales; añádelas a allowlist

Preguntas frecuentes

? ¿Cómo separo un admin legítimo de un atacante? Con baseline y contexto: quién administra qué, desde dónde y cuándo. Un logon administrativo de una workstation a otra fuera de horario, sin ticket de cambio, es sospechoso aunque use credenciales válidas.

? ¿Es suficiente el endpoint para detectar movimiento lateral? Ayuda mucho (Sysmon, logon events), pero correlacionar con la red (SMB, conexiones entre hosts) da la imagen completa y detecta lo que un host silenciado ocultaría.

? ¿Detecto Pass-the-Hash directamente? No hay un "evento PtH", pero su firma es un patrón: logon NTLM tipo 3 con credenciales explícitas (4648) en contextos donde se esperaría Kerberos. Se detecta por anomalía.

Referencias

- MITRE ATT&CK, Lateral Movement — <https://attack.mitre.org/tactics/TA0008/>
- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.
- Microsoft, "Securing lateral movement paths" — <https://learn.microsoft.com/>
- SpecterOps, BloodHound docs — <https://bloodhound.readthedocs.io/>
- JPCERT/CC, "Detecting Lateral Movement through Tracking Event Logs" — <https://jpcertcc.github.io/ToolAnalysisResultSheet/>

Siguiente clase

Clase 193 - Deteccion de C2 y beaconing